

Security+ 4.3 · Penetration Testing

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.3** —
Penetration Testing (6:21) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Penetration testing simulates real attacks to expose exploitable flaws and demonstrate impact. Rules of Engagement (ROE) define scope, timing, allowed techniques, and constraints. Responsible disclosure requires reporting findings to the vendor before public release. Testing types include white-box (full access), black-box (no access), and grey-box (partial access).

High-Yield Core Concepts Tested on Exam

- ROE (Rules of Engagement): defines what is permitted and prohibited during a pentest
- White-box: tester has full knowledge/access; black-box: no prior knowledge; grey-box: partial
- Responsible disclosure: report vulnerabilities to vendor before public disclosure
- Pentest validates real-world exploitability and business impact
- ROE includes scope, time window, techniques, and non-destructive constraints

Exam Tips & Classic Scenarios

- 'agreement on what the pentester can and cannot do' = ROE
- 'tester has no prior knowledge of the environment' = black-box
- 'report to vendor before publishing' = responsible disclosure

Typical Exam Scenario: A pentester agrees to attack only IP 10.0.0.5 during defined time windows, which is governed by the Rules of Engagement (ROE).

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.3 — Penetration Testing)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Corporate scenario (Penetration Testing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'ROE (rules of engagement): what CAN and CANNOT be done in the pentest.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: ROE (rules of engagement): what CAN and CANNOT be done in the pentest...

2. Corporate scenario (Penetration Testing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'White-box: with full access; black-box: with none'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: White-box: with full access; black-box: with none...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

3. Corporate scenario (Penetration Testing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'Responsible disclosure: reports to vendor before publishing'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Responsible disclosure: reports to vendor before publishing...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Penetration Testing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'agreement on what the pentester can and cannot do'=ROE'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'agreement on what the pentester can and cannot do'=ROE...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Penetration Testing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'pentester agreed to attack only IP 10.0.0.5 within defined windows' = ROE.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'pentester agreed to attack only IP 10.0.0.5 within defined windows' = ROE.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Penetration Testing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'ROE (rules of engagement): what CAN and CANNOT be done in the pentest'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: ROE (rules of engagement): what CAN and CANNOT be done in the pentest...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Penetration Testing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'White-box: with full access; black-box: with nothing.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: White-box: with full access; black-box: with nothing...

8. Corporate scenario (Penetration Testing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'Responsible disclosure: report to the vendor before publishing.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Responsible disclosure: report to the vendor before publishing.
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Penetration Testing): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 4.3) exam, an analyst evaluates the following technical requirement: 'agreement on what the pentester can and cannot do'=ROE'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'agreement on what the pentester can and cannot do'=ROE.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Penetration Testing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.3), an analyst evaluates the following technical requirement: 'pentester agreed to attack only IP 10.0.0.5 within defined windows'=ROE.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'pentester agreed to attack only IP 10.0.0.5 within defined windows'=ROE....
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) D — Implement the corresponding solution: ROE (rules of engagement): what CAN and CANNOT be done in the pentest....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Penetration Testing): ROE (rules of engagement): what CAN and CANNOT be done in the pentest. Rules of engagement define the scope, boundaries, and authorized actions for a penetration test, ensuring legal and operational compliance.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

2) B — Implement the corresponding solution: White-box: with full access; black-box: with none....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Penetration Testing): White-box: with full access; black-box: with none. This correctly distinguishes penetration testing approaches: white-box testing provides testers with full knowledge and access to systems, while black-box testing provides no prior knowledge, simulating an external attacker.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) B — Implement the corresponding solution: Responsible disclosure: reports to vendor before publishing....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Penetration Testing): Responsible disclosure: reports to vendor before publishing. Responsible disclosure is the ethical practice of notifying the vendor of a vulnerability and allowing a reasonable time for a fix before public disclosure, balancing security and transparency.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: 'agreement on what the pentester can and cannot do'=ROE....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Penetration Testing): 'agreement on what the pentester can and cannot do'=ROE.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

5) B — Implement the corresponding solution: 'pentester agreed to attack only IP 10.0.0.5 within defined windows' = ROE..

The correct answer is to implement the corresponding solution: define and follow Rules of Engagement (ROE). According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Penetration Testing), ROE specify the scope, timing, targets, and constraints of a penetration test, such as limiting attacks to a specific IP and time window, to ensure legal and operational safety. Distractor breakdown: • *Temporarily disable audit logs to accelerate system throughput*: Incorrect. This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001). • *Replace preventive technical controls with informal terms of adherence*: Incorrect. Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware. • *Allow shared access among administrators using generic credentials*: Incorrect. This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: ROE (rules of engagement): what CAN and CANNOT be done in the pentest....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Penetration Testing): ROE (rules of engagement): what CAN and CANNOT be done in the pentest.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

7) D — Implement the corresponding solution: White-box: with full access; black-box: with nothing....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Penetration Testing): White-box: with full access; black-box: with nothing. White-box testing provides the tester with complete knowledge of the system (source code, architecture, credentials), while black-box testing provides no prior knowledge, simulating an external attacker. These are standard penetration testing methodologies.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: Responsible disclosure: report to the vendor before publishing..

The correct answer is to implement the corresponding solution: follow responsible disclosure. According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Penetration Testing), responsible disclosure means reporting vulnerabilities to the vendor privately and allowing a reasonable timeframe for remediation before any public disclosure, thereby reducing risk to users. Distractor breakdown: • *Temporarily disable audit logs to accelerate system throughput*: Incorrect. This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001). • *Replace preventive technical controls with informal terms of adherence*: Incorrect. Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware. • *Allow shared access among administrators using generic credentials*: Incorrect. This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: 'agreement on what the pentester can and cannot do'=ROE..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Penetration Testing): 'agreement on what the pentester can and cannot do'=ROE. Rules of Engagement (ROE) define the scope, boundaries, and permitted activities for a penetration test, ensuring legal and operational compliance.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks,

injections, or runtime malware.

- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: 'pentester agreed to attack only IP 10.0.0.5 within defined windows'=ROE....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.3 (Penetration Testing): 'pentester agreed to attack only IP 10.0.0.5 within defined windows'=ROE.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.